

CyBlack Internship – September 2026 Application

Practical Task: Malware Hash Investigation & Third-Party Vendor Risk Assessment (ToR Legacy)

Prepared by: Elizabeth Sesebor

Date: 25th July 2026

Scope & Methodology

This report covers two assessments. Part 1 involved identifying and analyzing a suspicious file hash to determine its type, malicious classification, malware family, detection indicators, potential impact, and industry-specific risk (healthcare). This was carried out using hash-identification commands on Kali Linux (wc -m, hashid) and threat intelligence lookup via VirusTotal.

Part 2 is a passive, external vendor risk assessment of ToR Legacy's core digital asset, www.torlegacy.com, conducted on behalf of the Engagement Manager and Security Steering Committee. No active scanning, exploitation, or direct interaction with client infrastructure was performed. Findings were derived from DNS reconnaissance (DNSDumpster), domain registration data (WHOIS), certificate transparency logs (crt.sh), TLS configuration analysis (Qualys SSL Labs, SSL Trust), and internet-facing exposure checks (Shodan).

Summary of Key Findings (see full analysis in following sections for complete details)

SN	Category	Finding	Risk	Recommendation
1	Hash/Malware SHA-256	identified as Mirai/Gafgyt trojan (41/63 VT detections)	High	Block hash/IOCs across EDR; isolate affected endpoints
2	Health Impact	Risk to PHI, EHR/IoMT downtime, patient safety, HIPAA exposure	High	Prioritize healthcare-specific IR & IoMT network isolation
3	DNS	No TXT records found (SPF/DKIM/DMARC not visible)	High-Medium	Implement email authentication records with enforcing DMARC
4	TLS	TLS 1.0 still enabled; SSL Labs grade B	Medium	Disable legacy protocols, enforce TLS 1.2+
5	TLS	No HSTS; empty security headers	Medium	Implement HSTS and standard security headers
6	DNS/Domain	Cloudflare WAF active; registrar-lock in place	Low (positive)	Maintain current configuration

TASK Part 1

1. I identified the hash type based on its length, then verified this programmatically on Kali Linux by running `echo -n f02ce710874cd773c3c32730dc2536d14f4e419bf828d4a27664a24af5d4484f | wc -m`, which returned a character count of 64. I confirmed this using the `hashid` command, which identified it as SHA-256.

To determine whether the file was malicious, I searched the hash on VirusTotal. The result confirmed it as malicious, with 41 out of 63 security vendors flagging it. The file is a Trojan in Executable and Linkable Format (ELF) that exhibits several malicious behaviors: it downloads and executes secondary payloads using `wget`, `curl`, and `tfpt`; it enumerates running processes via `/proc` and terminates any matching a hardcoded list (including names like `condi`, `zxc9999`, and `watchdog`) to eliminate competing malware; and it contains network-scanning capabilities, using SSDP M-SEARCH requests to discover and potentially infect other devices on the network. VirusTotal classified the malware family as Trojan.Mirai/Gafgyt (also tagged as Mirai, Gafgyt, and `usbgo26` variants).

2. Since the file is in ELF, it primarily targets endpoint and IoT/Linux-based systems. Detection would typically rely on an organization's Endpoint Detection and Response (EDR) platform, configured with predefined playbooks and rules referencing known malicious hashes such as this SHA-256 value. When a match is detected on any endpoint, the EDR should raise an alert and automatically quarantine the affected device as an initial response.

Automatically, the file can be detected through behavioral indicators, including: its process tree behavior (suspicious child processes or execution patterns); file system changes, such as the creation of suspicious paths and folders (e.g. `/tmp/condi`, `/var/condibot`); network communication patterns, including connections to known malicious IPs/domains or unusual DNS request activity; and registry key modifications, such as unauthorized changes to `Run` or `RunOnce` keys used for persistence. Once these behavioral patterns are codified as detection rules within the EDR, the system can automatically flag and respond to the malware without relying solely on static hash matching.

3. This malware effectively hijacks the infected device, gaining full control over its file system, network activity, running processes, IDEs and overall system environment — allowing it to modify, create, mimic, or isolate components at will.

On the infected device, the impact is severe: it can exfiltrate sensitive and financial data, harvest login credentials, consume CPU and memory resources, execute arbitrary code, and even access peripherals such as webcams.

Its impact on other systems is primarily through lateral movement — the attacker can use the compromised device as a foothold to scan other endpoints and servers within the network, exploit weak protocols such as SMB, and gain further unauthorized access. Compromised devices can also be leveraged to launch DDoS attacks against external targets or to propagate ransomware across connected systems.

4. Trojan malware can be used to execute several types of attacks:

- Remote Access Trojan (RAT) activity — remotely accessing webcams, capturing keystrokes, and stealing banking credentials, personal data, or intellectual property.
- Ransomware — locking systems and demanding payment for restored access.
- Supply chain attacks — compromising software used to manage third parties, vendors, or clients.
- Phishing — using compromised infrastructure to distribute malicious emails.

Mitigation strategies: when trojan is being detected on an endpoint, the first thing to do is to immediately isolate any infected device by disconnecting it from the network; segmenting networks into isolated zones to limit lateral movement; deploying automated EDR tools for rapid detection and containment; enforcing Multi-Factor Authentication (MFA), particularly biometric-based factors such as lens scan or finger prints, to reduce the impact of credential theft; applying the principle of Least Privilege Access by removing unnecessary administrative rights from standard user accounts; and blocklisting known malicious IP addresses and domains associated with the malware.

5. In a healthcare setting, this type of malware poses several serious risks. It can compromise Protected Health Information (PHI), exposing sensitive patient records and financial data. It can also cause medical system downtime — for example, if deployed as ransomware, it could lock Electronic Health Record (EHR) systems, forcing staff to revert to paper records, delaying access to diagnostic equipment such as MRI machines, causing scheduled surgeries to be cancelled, and preventing clinicians from accessing patient history — all of which can lead to serious operational disruption and, in severe cases, risk to patient life if ransom demands are delayed or unmet.

Additionally, because many hospitals rely on Internet of Medical Things (IoMT) devices, lateral spread of the malware across the network could cause connected medical devices to freeze, disconnect, or fail to update, further disrupting critical care services. Finally, an incident of this nature would carry significant regulatory exposure, particularly under HIPAA-type compliance obligations for protecting patient data.

TASK Part 2

1. DNS and Domain Findings

Using DNSDumpster, I found that ToR Legacy's domain is fronted by Cloudflare (CloudflareNet), with direct access to the origin server IP blocked — a positive control that hides the true backend server and reduces the site's exposed attack surface. However, the same scan returned no MX, TXT, or NS records. The absence of visible TXT records is a concern, since SPF, DKIM, and DMARC — the controls that prevent attackers from sending spoofed emails "as" the domain — are typically stored there; if genuinely absent, this leaves the domain open to email impersonation and phishing attacks using its name, which I'd rate as medium-to-high risk and recommend verifying with a second source before ToR Legacy implements all three records with an enforcing DMARC policy. The missing MX record is lower risk but should be confirmed with the client, since it's unclear whether mail is simply handled through an undetected configuration rather than being absent altogether.

Separately, a WHOIS lookup confirmed the domain's nameservers point to ns.cloudflare.com (consistent with the DNSDumpster finding) and showed a domain status of "Client Transfer Prohibited" — a registrar-lock that protects against unauthorized domain hijacking, which is good practice. The domain was last updated in January 2026 and is set to expire in August 2026; while not an immediate concern, I'd flag this as a low-risk monitoring item, since a lapsed domain registration is a well-known and severe attack vector if renewal is missed.

2. TLS and Certificate Findings

A crt.sh certificate transparency search showed ToR Legacy's certificate history from 2022 to 2026. In 2022 and 2023, certificates were issued by Let's Encrypt for subdomains including torlegacy.impactherwebsitestwentyeight.com and webdisk.torlegacy.com, both matching the identity www.torlegacy.com. In 2024, certificates covered mail., cpanel., and webmail.torlegacy.com, matched to an unusual identity, www.torlegacy.com.projectsimpactherthree.com. This pattern is consistent with shared-hosting auto-issued SAN certificates (common with cPanel/AutoSSL setups), but the odd matching-identity domains are worth flagging as a medium risk, since they suggest the site may have been on shared or third-party hosting infrastructure where certificate scope wasn't tightly controlled — a potential subdomain takeover or cross-tenant exposure risk if those subdomains are no longer maintained. From 2025 onward, the domain moved to a Sectigo-issued certificate scoped cleanly to torlegacy.com, which reflects a more mature, direct certificate management setup — a positive shift. Running the live site through Qualys SSL Labs returned a grade of B across all four servers tested, indicating the configuration is functional but not optimized to current best practice. A deeper scan via SSL Trust's SSL/TLS Checker showed the server still offers the deprecated TLS 1.0 protocol alongside TLS 1.2 and 1.3 — this doesn't meet the current industry baseline (TLS 1.2+ minimum, TLS 1.3 preferred) and allows legacy/downgrade-related attacks, so I'd rate this medium risk and recommend disabling TLS 1.0 (and 1.1, if enabled) entirely. The scan also showed no HSTS support, meaning the site doesn't instruct browsers to enforce HTTPS-only connections, leaving a window for protocol-downgrade or SSL-stripping attacks — also medium risk, recommend enabling HSTS with a long max-age. Security response headers were reported as empty, a further medium gap, recommend implementing Content-Security-Policy, X-Frame-Options, and related headers.

On vulnerabilities, the site is not vulnerable to Heartbleed, POODLE, CRIME, BREACH, or RC4-based attacks, and no NULL/export/LOW/3DES ciphers are offered — all positive signs. It does show residual exposure to BEAST (mitigated in practice since TLS 1.1/1.2 are also supported) and a potential Lucky13 exposure due to remaining CBC-mode ciphers — both low risk given the mitigating factors, but I'd still recommend prioritizing modern AEAD ciphers going forward. Forward secrecy is properly offered, using strong curves (X25519, secp384r1/521r1) — a solid, modern configuration worth preserving.

3. Security Gaps (Other Exposure)

A Shodan search for ToR Legacy's infrastructure returned no results, meaning no internet-facing services tied to the domain/IP have been indexed by Shodan's scanners. This is a positive finding — it suggests the origin server isn't directly exposed to the internet (consistent with the Cloudflare-fronted setup identified earlier) and reduces the likelihood of an easily discoverable open port or misconfigured service. I'd note this as low risk, with a recommendation to periodically re-check Shodan/Censys, since exposure can change over time as infrastructure evolves.